CW2 – Digital Forensics for Cyber Security

COMM069 Digital Forensics, semester 1, 2025/26
Released: Week 11; Due in: Week 14

This coursework in centred around topics covered in weeks 6–10, specifically network and memory forensics and anti-forensics. In Exercise 1, you will be required to combine techniques developed during the labs, extracting anti-forensically protected data from network traffic and memory dumps and then undoing the forensic countermeasures. In Exercise 2, you will be required to develop a small solution illustrating one out of a choice of possible mini-projects, demonstrating understanding of one of the techniques covered in class. Finally, you will have to answer some questions on the topics covered during lectures. To best solve this CW, you will need to do some independent reading on some application-layer protocols and tools not covered in class.

Note:

- Please read the whole coursework first, including any external references mentioned in the text.
- This coursework is *individual*. To prove that you yourself did try to solve this coursework, you will have to submit screenshots annotated with your username in a particular way described below (see Deliverables Checklist). Please do not try to counterfeit these screenshots, as it will count as academic misconduct. **Please note the annotations have been changed from CW 1.**
- To solve this coursework, you will need tools that you can find preinstalled in the Lab VMs. To access these from home, you will first need to connect to Surrey's VPN service (instructions: `https://surreynet.surrey.ac.uk/staff-services/it-services/working-campus`) and then connect to the Lab VMs by either using `https://remotelabs.eps.surrey.ac.uk` to log into a Lab workstation and from there use Remmina (as we did during the Labs), or by using a VNC client directly from your computer (such as Remmina on Linux or RealVNC on Windows and MacOS).
- You are allowed to solve the exercise on a different OS (such as a locally managed Kali VM). However, you must make sure that the solution to Exercise 2 runs correctly on the Lab VMs, and you must provide evidence tokens.

Exercise 1: A case of corporate espionage

Forensics setting: You have been called to investigate a recent security incident in a small accounting company. The intrusion detection system detected suspicious traffic on

the network and hence recorded forensically relevant traffic and memory. The company IT team believes malware may have spread through the network and given remote access to hackers. You are tasked with analysing the recovered data, reconstructing the events, identifying and recovering any possible data leaks, and writing a forensic report regarding your investigation.

Technical context: The data collected belongs to two machines: a Windows workstation with two IP addresses, `10.0.2.15` and `10.13.13.101` (one per NIC), and a Linux company server with IP address `10.13.13.145`, as shown in Figure 1. For both machines, a traffic capture was performed. For the Windows machine, a memory dump was generated during the suspected breach.

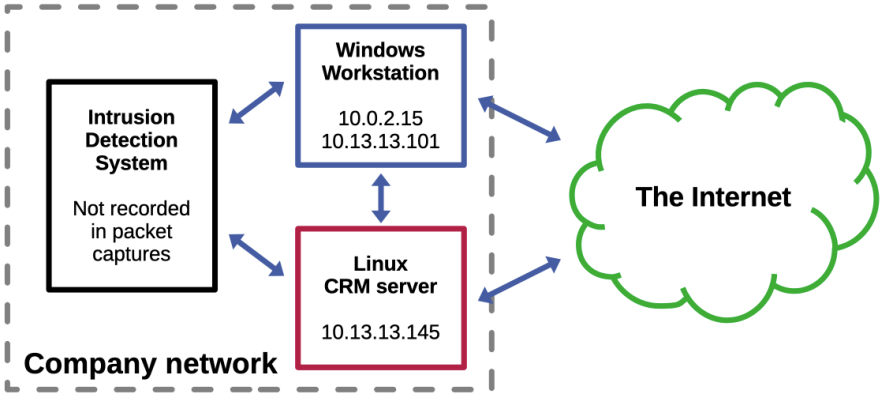

Figure 1: Company network

Materials: Extract the **cw2-espionage.zip** file you find on Surrey Learn, containing:

- `win.pcap`: the traffic capture from the Windows workstation.
- `lin.pcap`: the traffic capture from the Linux server.
- `win.mem`: the memory dump from the Windows workstation.

Hint: To perform most of the analysis in this exercise, you will want to analyse network traffic and carve files out of there. You can find an example of how to do that on SurreyLearn. Protocol filters are a very important feature of Wireshark. You can find common protocol filters in Table 1.

Table 1: Wireshark filters for common protocols.

Port no.	Application	Transport	Wireshark filters
21	FTP	TCP, UDP	ftp, ftp-data
22	SSH-SCP	TCP, UDP	ssh
25, 587	SMTP	TCP	smtp
53	DNS	TCP, UDP	dns
80	HTTP	TCP, QUIC	http
1194	OpenVPN	TCP, UDP	openvpn
110	POP3	TCP	pop
143	IMAP4	TCP, UDP	imap
443	HTTP over TLS (HTTPS)	TCP, UDP	tls

Report structure (5 pts)

You are asked to return the results of your investigation in the format of a forensic report in the style seen in class in Week 10. You can use the template available in Surrey Learn, simply download it and add your content. Use your preferred text processor (Word, LaTeX, or other similar tool) to produce a report with the following sections:

- **Report Information:** List the investigators (the author of the report) and the report date
- **Executive Summary:** Give a brief summary of your key findings.
- **Investigator Background:** Detail who you are, your student number, and what relevant training you are currently undertaking.
- **Submission Details:** What data were you given to examine, and what devices were the data related to?
- **Analysis of Exhibits:** Report on the actual investigation. Start with the initial examination, noting down what traces you identify as you go.
- **Exhibits Produced:** Answers to the questions in the exercise, any source code you have written to answer these questions, and any outputs generated from that source code. Please clarify what questions your answers belong to within this section.
- **Appendices:** Any relevant information you may believe is necessary to add. E.g. a list of references to protocols not seen in class that may be involved in the case; for example, if the SMTP protocol is involved, a definition of the "SMTP" acronym and a link to its specification, `https://doi.org/10.17487/RFC5321`.)

The clear and appropriate formatting of your report **counts for 5 points** of the final mark.

Tasks (50 pts)

1. Identify the initial breach into the company system. Indicate: (10pts)
   (a) the time of breach, (2 pts)
   (b) the vector (such as a phishing email, a virus, a mistaken configuration abused by the attacker, etc), (2 pts)
   (c) the network activity related to the breach, (2 pts)
   (d) the immediate consequences (was a backdoor installed? a file stolen? a user created in the host system?) (2 pts)
   (e) Identify the user who was logged into the Windows workstation during the breach. (2 pts)
2. For every file exfiltration (a total of five) you can identify, report: (20 pts)
   (a) The file name. (1 pt)

(b) The local machine it was taken from (Windows workstation and Linux server), and the remote IP it was transmitted to. (1 pt)

(c) The mean of transmission (e.g, HTTP upload, email, other protocol). (1 pt)

(d) Whether any anti-forensic technique was used, and if any, which technique it was. (1 pt)

3. Other than file exfiltration, identify any further consequences to the company systems. (2 pts)

4. Whenever possible, recover the content of the transmitted file. If an anti-forensic technique was used, such as steganography (12 pts)

   (a) Describe how the anti-forensic technique works

   (b) Implement a script that recovers the original file, or argue why this is not possible, and what you can learn about the file regardless.

5. Identify any suspicious IP addresses that the company computers communicated with. (2 pts)

6. Identify the Windows version and the Office package used by the Windows workstation (2pts)

7. While the attackers were successful, they left some traces behind, including login credentials for a remote server. Identify these credentials. (2pts)

Exercise 2: Development of a forensic tool (25 pts)

In this exercise, you are required to develop a small forensic tool, extending or automating one of the techniques or tools seen in class. You can choose a language of your choice, as long as it is widely available today (Java, Python, C/C++: yes, Fortran, COBOL, Prolog: no). Your solution **must run on a Lab VM without advanced modifications**.

Your answer to this section must be a ZIP file that contains the following:

- Source code and a README file that gives clear instructions to demonstrate your tool from the moment one extracts the ZIP file. Note, if any dependencies need to be installed, this should be part of the instructions in the README file. The README file can be a text file, a Word document, or a PDF file.

- A document where you show using your tool step by step, including text and screenshots in a format similar to that of Problem 1 in the Week 9 Lab. This could also be a short screen recording where you show and explain how to use the tool.

You can choose from one of the following projects:

1. Automating volatility2: Create a script that, given a memory dump from a Virtual Machine (such as the one in Exercise 1, or the one in Problem 3 of the Week 10 lab), displays:

   - The operating system version
   - The running processes (highlighting whether there are any processes hidden from pslist)

- The open network connections
- The logged users
- The contents of any terminal/console windows open.

2. Content moderation: create two scripts,

   - one is given a directory of images and returns a file or database containing PHF hashes for two different PHFs
   - the other is given a new image and the file/database of hashes from one such directory, and returns whether there are any possible images in the database similar to the provided image

3. Better steganography: write a script/application that, given an image in either JPEG, PNG, GIF or BMP format, tries to detect if there is steganographically encoded data and returns

   - A boolean value saying whether the tool has detected hidden encoded data or not
   - The encoded data, if any
   - The encoding method (LSB or CAT), if any

   Note: You should not limit yourself to the LSB encoding used in the lab. In that case, only the red channel was ever used for encoding, and only column-by-column encoding was used. Instead, try to detect either column by column or row-by-row, and attempt to recover data from any of the three colour channels (red, green, blue).

Your code will be marked using the following metrics:

- Reproducibility (clarity of instructions, ability to execute): 10 pts
- Functionality: effectiveness at solving related exercises from the labs (and extensions when applicable, such as for LSB steganography): 10 pts
- Quality of the code (comments, readability of code): 5 pts

Questions (20pts)

1. An anti-forensic technique central to network forensics is encryption of data in transit. Mention one forensic technique of your choice that can be used to recover encrypted data, describing when it can and cannot be used, and how easy it is to apply it to incident response and to criminal investigations. Include a reference to where this technique is described in the lecture slides or in the course bibliography. (3pts)

2. Describe one technique used to automatically identify harmful images. Explain how this could be deployed to check images uploaded to social media, what limitations it has, and whether any ethical considerations should be taken when deploying it. Include a reference to where this technique is described in the lecture slides or in the course bibliography. (4 pts)

3. For each layer of the TCP/IP (Application, Transport, Internet, Link), describe one piece of information specific to that layer (such as UDP ports in the Transport layer) of forensic relevance, and how it could be used as part of an investigation. Include a reference to where this information is mentioned in the lecture slides or in the course bibliography. (4 pts)

4. In class, you have seen the principle behind LSB steganography. Explain what kind of picture is well-suited to embed encrypted information and why. (3pts)

5. Briefly explain the principle behind Onion routing that permits a user's internet navigation to stay anonymous, and point out the implicit system requirement that law enforcement allegedly invalidated and that permitted them to deanonymise users as part of "Operation Liberty Lane". (3pt)

6. Explain why the memory forensics framework Volatility includes two different commands for listing running processes in a computer (`pslist` and `psscan`), and how these differ in inner working. (3pt)

Deliverables Checklist

- Exercise 1: A ZIP file named `ex1.zip` containing the report in the specified format with all the answers, and any further evidence such as recovered data, developed scripts including text instructions to run them, screenshots with evidence token as per below.
- Exercise 2: A ZIP file named `ex2.zip` containing your forensic tool, a README file, and evidence of it working, accompanied by an evidence token as per below.
- Questions: A PDF file `questions.pdf` with all the answers to the final questions.
- For every script or data recovered through software, provide an <u>evidence token</u>, that is, a screenshot where the following are visible at the same time:
  - The recovered data
  - The terminal, with the following command evaluated `echo $(date +%s) $(date)`
  - The browser, opened to Surrey Learn in such a way that the top-right displays your name.

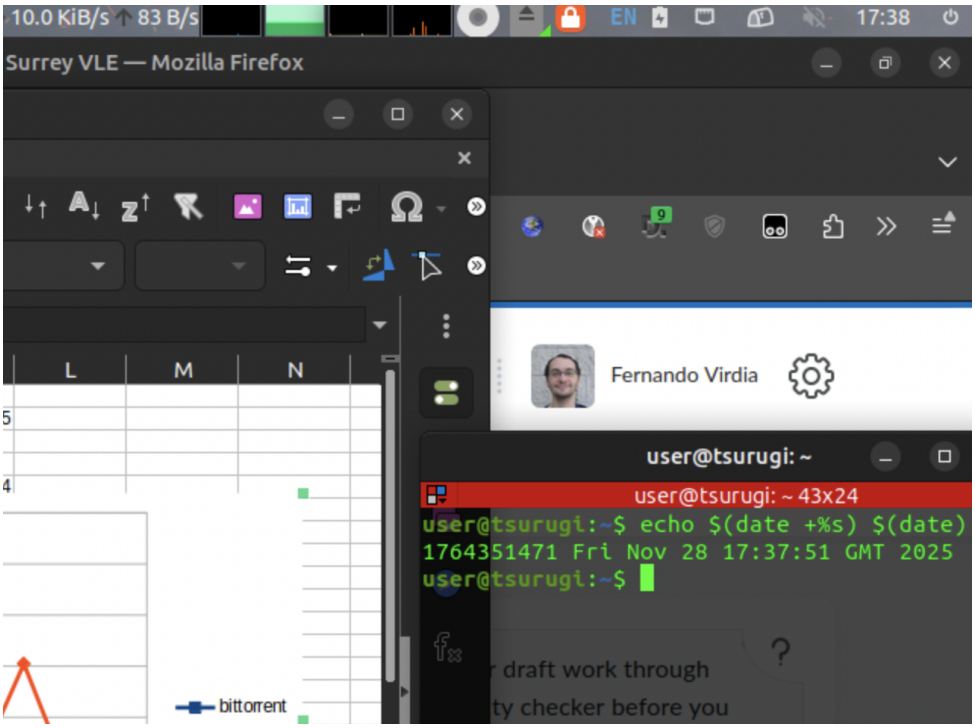

Figure 2: Example of partial evidence token. In your report, the full screen should be visible.